金融级 LLM 护栏与审计流水线

Financial LLM Guardrails & Audit Pipeline — Technical Card

作者 Angran Fei • AkuWezInbox@proton.me | **适用范围** 香港金融机构与数码港科技企业的 LLM 应用前置防护，对齐《个人资料（私隐）条例》（PDPO）六项保障资料原则

说　明

部署于模型调用链前端的确定性护栏：**Prompt 注入与越狱拦截、HKID 与银行账号等敏感实体的可逆脱敏、请求级审计留痕**。纯标准库实现、无第三方运行时依赖、可内网离线部署；`guard()` 统一入口与 LiteLLM / FastAPI 挂载点五行内接入。指标均为本机实测，区分「样本内」与「留出」两种口径列示。

一　防御架构



图 1　护栏位于模型调用链前端。第 ④ 步后模型侧不再出现原始个人资料；第 ⑥ 步还原权限与调用方身份绑定，完成后立即销毁映射。

两条语义约束决定误拦率：① 指令覆盖类必须指向【指令性宾语】，故「忽略上一笔冲销分录」不计分；② 角色扮演类按人格对象分级，业务角色（复核人 / auditor）仅记录不拦截。无校验算法的实体（护照、电话）须上下文锚定或边界守卫；Vault 写入全程持锁，杜绝占位符碰撞。

二　评测口径

评测集四部分：**对抗集 120 条**（6 家族各 20）、**正常集 80 条**（含 **16 条形似攻击的真实业务查询**作硬负例）、**留出集 41 + 30 条**（规则冻结后编写：格式劫持、身份冒充、载荷分片、跨语种）、**脱敏集 60 文本 / 140 标注实体**（内嵌 NAV 金额、ISIN、发票号等干扰数字以测误脱敏）。

风险提示

样本内与留出必须分开读。 规则 v2 系查看 v1 漏报后修正所得，其 120 条成绩属**样本内（in-sample）**指标；留出集在规则快照冻结（MD5 存档）后编写、**仅运行一次**且未回流改规则，是唯一未受污染的泛化估计。**延迟按 10 轮重测取中位数**，单次观测在共享单核环境下会被抖动顶高，不作指标。

三　合规指标卡

注入检测	v1 基线（盲测）	v2 样本内	v2 留出（泛化）
注入拦截率	70.83%　(85/120)	**99.17%**　(119/120)	**41.46%**　(17/41)
正常业务误拦率	1.25%　(1/80)	**0.00%**　(0/80)	**0.00%**　(0/30)
精确率 / F1	98.84% / 82.52%	**100.00%** / 99.58%	**100.00%** / 58.62%

样本内攻击家族（各 20 条）	v1	v2	留出攻击向量	v2
直接指令覆盖	80%	**100%**	输出格式劫持与包装（13 条）	**23.08%**
系统提示词窃取	60%	**100%**	权威身份冒充（11 条）	**45.45%**
角色扮演诱导	85%	**100%**	载荷分片与多轮铺垫（10 条）	**60.00%**
间接注入	70%	95%	跨语种指令（7 条）	**42.86%**
编码与变形绕过	60%	**100%**	留出正常集误拦（30 条）	**0.00%**
金融数据越权导出	70%	**100%**	—	—

脱敏实体	确认方式	召回	延迟项	p50	p95
HKID	mod-11 校验	25/25	注入检测	0.15	0.28
银行账号	清算行代码	30/30	PII 脱敏	0.05	0.07
支付卡号	Luhn 校验	10/10	**合并 p95**	—	**0.37**
其余五类实体	上下文锚定	75/75	复现区间	—	0.36–0.40
合计 140 实体	**召回 100%**	**精确 100%**	**可逆 100%**	—	—

四　合规映射与部署建议

能力边界已由留出集界定：高精确率、低泛化召回。 两轮共 110 条正常业务查询（含 46 条硬负例）**零误拦**；但面对未覆盖的攻击家族，拦截率由 99.17% 降至 **41.46%**，其中**格式劫持（23.08%）与身份冒充（45.45%）最薄弱**——二者均不含传统注入关键词。

PDPO 映射	本护栏对应机制
DPP3　使用限制	入模型前最小化脱敏，模型侧仅见占位符，个人资料不因调用大模型而扩大使用范围
DPP2(2)／DPP4　保留与保安	Vault 仅存活于单次会话：默认 TTL 300 秒、设容量上限、出站还原后 `purge()` 即时销毁；HMAC 密钥由环境变量注入；审计仅录实体类型与数量
DPP6　查阅及改正	资料当事人的查阅与改正请求（须于 **40 个历日**内回应）可经可逆映射定点处理，无需解除全局脱敏

层	职责	依据
第一层　本护栏	确定性前置过滤：亚毫秒、零误拦、可审计、可离线	延迟与误拦率实测支持常态化全量开启
第二层　模型分类器	补齐泛化召回，覆盖语义化改写与跨语种	留出集 41.46% 表明规则层无法独立承担召回
第三层　出站控制	响应侧校验：占位符是否被还原、是否含未授权实体	格式劫持类攻击的落点在出站而非入站

说　明

已知边界：① 脱敏集由 12 类模板生成，100% 召回反映规则对模板的覆盖度，不等于对任意格式文档的泛化能力；② 中文姓名依赖字段标签锚定，无标签的自由文本姓名不在覆盖范围；③ 跨轮载荷拼接须在会话层防护。

Angran Fei • AkuWezInbox@proton.me　|　评测程序、数据集与规则快照（MD5 冻结）均可复现：`src/evaluate.py`、`src/eval_holdout.py`